

Who Authorized This Commit?

PAPER and the Case for Governance-Native AI Communication

Patrick Rho
Patty Research

August 2026

Abstract

An AI coding agent can read a private repository, choose what leaves the machine, select a model, request tools, rewrite a file, and produce a commit. Yet after the commit exists, a surprisingly basic question is difficult to answer: *who was authorized to cause it?* Today’s systems can usually recover pieces of the answer from API credentials, gateway decisions, tool logs, and Git history. They cannot reliably show that the same bounded authority governed the entire path from human intent to model invocation to executable side effect. The missing abstraction is not another log. It is an authority-bearing exchange.

We present PAPER (Patty AI Provenance & Enforcement Relay), a stateful protocol that makes governance part of AI communication itself. Its core primitive, the *Governed Exchange*, binds an enrolled peer and human identity to a short-lived Capability Lease, an immutable Policy Epoch, inline Relay Verdicts, a server-authoritative model package and endpoint, and a content-addressed Provenance Spine. The result is a live exchange in which a model may propose an action but cannot manufacture the authority to execute it, and in which evidence is produced along the causal path rather than reconstructed afterward.

We develop this design, define its security boundary, and report measurements from a Go prototype. Record encode/decode takes a median 290.2 ns at 1 KiB and 97.0 μ s at 1 MiB; an evidence-chain update takes 73.05 ns; and Ed25519 sign-and-verify takes 42.7 μ s on an Apple M4 Pro. These are primitive costs, not an end-to-end performance result. Production authentication, policy-pipeline latency, TTFT, scale, and provenance fidelity remain to be evaluated. The larger result is architectural: if agents can cause durable effects, authority and causal evidence should be first-class properties of the protocol that carries their work.

1 Introduction

Consider a plausible incident. A developer asks an agent to repair a failing authorization test. The agent selects six repository files as context, invokes a model advertised as “Code Standard,” receives a shell-tool proposal, runs a

migration, edits two files, and creates a commit. Hours later, the migration is found to have exposed tenant data. The organization now asks:

- Which human and which installed agent initiated the work?
- Was that agent allowed to disclose those six files to that model?
- Which immutable policy version permitted the migration command?
- Did the model merely propose the command, or did an authorized runtime execute it?
- Which exact model package and serving endpoint produced the proposal?
- Which parts of the final commit survived from model output after human edits?

Every component may have a log. That is precisely the problem. API authentication identifies a caller at one boundary; a gateway records a routing or policy decision at another; a sandbox records execution; Git records the resulting artifact. The organization must reconstruct one causal and authorization story from records produced under different identifiers, clocks, retention policies, and trust assumptions. A gap or ambiguity is discovered only after the side effect has already occurred.

This failure is not fundamentally an observability failure. It is a *protocol-model failure*. Conventional AI interfaces transport prompts, tokens, tool calls, tasks, and artifacts. They do not require the live exchange to carry the bounded authority under which those objects may cause effects. Consequently, governance is middleware surrounding the exchange rather than a condition for the exchange to advance.

PAPER asks what changes if we reverse that relationship. Instead of transporting intelligence first and reconstructing authority later, the protocol carries intelligence *inside an authority-bearing envelope*. A protected exchange cannot advance merely because a TLS connection exists or a model emitted a tool call. It advances only when the relevant identity, purpose, lease, policy epoch, model resolution, and Relay decision agree. Figure 1 illustrates this shift.

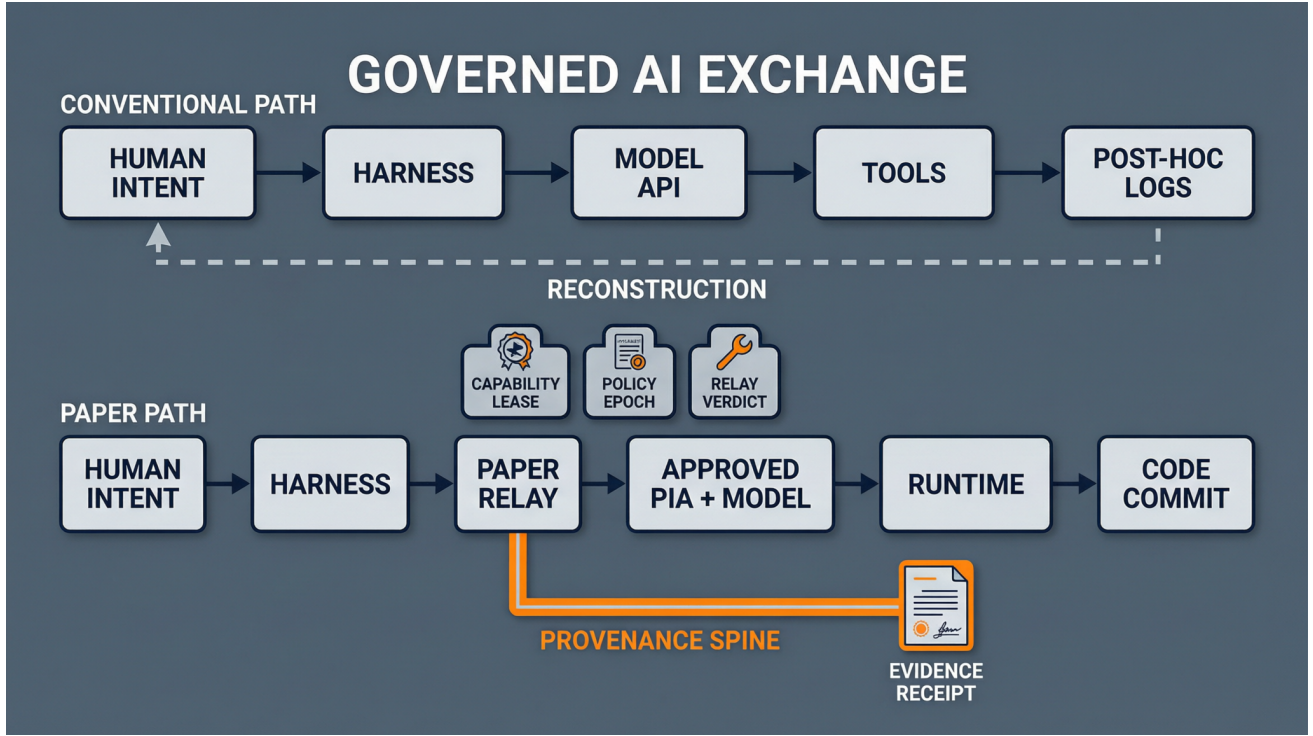


Figure 1: The architectural inversion. Conventional systems transport the interaction and reconstruct authority from logs afterward. PAPER makes bounded authority, enforcement, model identity, and causal evidence conditions of the live path. The illustration is conceptual and contains no empirical data.

1.1 Contributions

The paper advances one thesis: *an agentic AI protocol should carry not only messages and actions, but the authority and causal evidence that make those actions legitimate*. Three contributions support that thesis:

1. **Governed Exchange.** We define a protocol lifecycle in which human and peer identity, purpose-bound Capability Lease, immutable Policy Epoch, model authority, and inline Relay Verdict are prerequisites for protected actions. A model proposal is data; execution authority remains external to the model.
2. **Causal authority chain.** We connect user-facing model choice to a signed model package and leased endpoint, and connect intent, disclosure, inference, tool activity, edits, and artifacts through a content-addressed Provenance Spine and signed receipt. The goal is not more telemetry, but a verifiable answer to *why this effect was allowed to happen*.
3. **Measured prototype foundation.** We implement framing, canonical objects, signatures, evidence chaining, transport foundations, and a development Relay-to-PIA path in Go. We report reproducible primitive costs and an explicit audit of what the prototype does *not yet prove*.

The novelty claim is deliberately compositional. Secure transport, capabilities, provenance DAGs, signed receipts, and tool protocols already exist. PAPER’s claim is that their authority semantics belong in one live state machine

at the Harness–Relay–inference/runtime boundary. If this thesis holds, governance becomes enforceable before an effect and evidence becomes a protocol output rather than a forensic coincidence.

2 The Missing Layer

The motivating incident exposes three mismatches that recur in agentic systems.

Authentication is not authorization history. A valid API credential can establish who opened a request without establishing which repository, purpose, tool class, model artifact, or side effect that identity was authorized to use throughout a long-running task. Agentic work outlives individual requests and crosses components whose authorization models are rarely identical.

Model output is not execution authority. Tool-calling formats make a proposed action machine-readable. They do not make it legitimate. If a model can cause execution merely by emitting the right syntax, untrusted repository text can attempt to acquire authority through prompt injection. The enforcement boundary must distinguish *proposal*, *approval*, and *execution* as different events with different principals.

Logs record events; they do not necessarily prove one causal path. Correlated identifiers help, but correlation is not the same as a protocol-enforced chain. A durable answer to “who authorized this commit?” must bind the action to the authority and policy that existed *before* execution, then preserve how its result changed through later human and automated work.

These mismatches suggest a missing layer between secure transport and application-specific governance: an exchange abstraction that carries identity, bounded authority, immutable policy, enforcement decisions, and evidence as coordinated protocol state.

3 Adjacent Systems and Novelty Boundary

Model APIs and gateways. HTTPS/JSON and streaming model APIs are effective request/response interfaces. Gateways can add authentication, quotas, policy, and logging. PAPER differs primarily in the unit of state: authorization and evidence are bound to a long-lived governed session and exchange rather than reconstructed from independent middleware events.

MCP and A2A. The Model Context Protocol (MCP) standardizes interactions between AI applications and context/tool providers [8]. Agent2Agent (A2A) standardizes agent discovery, tasks, messages, and artifacts [1]. PAPER does not position either as an inferior transport. MCP can exist behind a governed tool broker, and A2A can operate at an agent-to-agent boundary. PAPER targets the narrower boundary between a human-facing engineering Harness, inline policy enforcement, controlled inference/runtime infrastructure, and software provenance.

Runtime governance and agent security. MI9 examines integrated runtime governance for agentic systems [15]; AgentDojo provides an environment for prompt-injection attacks and defenses [4]; and argument-level provenance work highlights the mismatch between coarse authorization and tool arguments [5]. PAPER is complementary: it defines protocol objects and state transitions through which identity, policy, tool authority, and evidence can be enforced and exported.

Supply-chain provenance. in-toto records signed metadata about supply-chain steps [6, 14], while SLSA defines provenance expectations for build and source tracks [11]. PAPER addresses an earlier interactive phase, before a build artifact necessarily exists. A PAPER receipt may later feed an in-toto or SLSA-oriented attestation.

Identity and cryptographic building blocks. SPIFFE provides workload-identity conventions [12]. PAPER reuses TLS 1.3 [9], QUIC [7], deterministic CBOR [3], COSE [10], HPKE [2], and COSE receipts [13]. These

standards provide transport and object-security primitives; they do not define the application-level authority model proposed here.

The sharpest novelty boundary is therefore this: MCP can describe a tool, A2A can describe an inter-agent task, SPIFFE can identify a workload, a gateway can enforce policy, and in-toto can attest a supply-chain step. PAPER asks whether a single governed state machine can bind those adjacent concerns at the moment an AI engineering action crosses from proposed computation into an authorized, durable effect.

4 Requirements and Threat Model

4.1 Design requirements

The incident questions become six protocol requirements: (R1) bind every protected action to an enrolled peer and human identity; (R2) constrain authority with short-lived, purpose-bound grants; (R3) bind every enforcement decision to an immutable policy revision; (R4) identify the served model artifact and endpoint more strongly than a caller-supplied name; (R5) separate model proposal from runtime authorization and execution; and (R6) emit causal evidence that survives beyond ordinary application logs.

The system must also operate with a temporarily unavailable control plane. Relays therefore consume signed or authenticated snapshots, revocation state, policy epochs, model catalogs, and leases. Availability under stale state is bounded by explicit expiration and deployment policy rather than implicit cache behavior.

4.2 Adversaries and non-goals

We consider network attackers, unregistered clients, stolen or replayed credentials, compromised Harnesses, prompt-injected content, malicious tool output, model-name spoofing, cross-tenant mistakes, and evidence tampering. A Relay or administrator may also be malicious or compromised. The protocol aims to make such authority and evidence boundaries explicit; it cannot make a trusted plaintext Relay unable to inspect content, prove that a model behaved correctly, or prevent a fully compromised endpoint from acting outside the protocol. Hardware attestation and formal verification are optional future profiles, not assumptions of the prototype.

5 The Governed Exchange

The Governed Exchange is PAPER’s unit of accountable AI work. It is larger than an API request and smaller than an entire developer session. It begins when a Harness declares a protected purpose and ends with a receipt that commits to the resulting evidence. Within that boundary,

inference, context disclosure, model selection, tool use, approval, and output are transitions of one authority-aware state machine.

A useful mental model is a transaction whose commit condition is governance rather than database consistency. TLS answers whether bytes arrived through a protected channel. The Governed Exchange additionally asks whether the sender, purpose, policy, model, and proposed effect agree. Failure at a required gate prevents the protected transition; it is not merely recorded for later review.

5.1 Architecture and peers

The administrative Control Plane enrolls identities, issues policy and model state, manages revocation, and indexes evidence. It is authoritative but is not placed synchronously on every token. A Relay terminates Harness connections, validates cached signed state, performs inline policy decisions, routes approved inference, and appends evidence. A Patty Inference Agent (PIA) is a registered peer in front of a serving engine. The PIA translates PAPER’s semantic request into a local engine interface; a raw model endpoint is never routing authority for the Harness. A runtime executes tools only after an independent authorization transition.

5.2 Why this is a protocol, not a larger log schema

A log schema can describe an allow decision. It cannot require that the decision precede disclosure, model allocation, or tool execution. A protocol state machine can. PAPER therefore makes the evidence-worthy boundaries—identity binding, lease presentation, epoch binding, verdict, dispatch, tool authorization, and closure—observable transitions that peers must complete in order. This ordering is the core distinction between governance-aware middleware and governance-native communication.

5.3 Transport and representation

QUIC is the preferred binding because independent streams reduce head-of-line coupling; TLS 1.3 over TCP is the fallback. Both use the same application semantics and ALPN identity. Records contain a fixed prelude, canonical header, payload, logical lane identifier, and lane sequence. Deterministic CBOR provides reproducible object encoding. COSE signatures protect credentials, leases, epochs, model manifests, and receipts where object-level verification is required.

Transport authentication alone is insufficient. An application proof must bind peer credential, nonces, negotiated profile, and channel context so that a credential proof captured on one connection cannot be replayed on another. The present prototype defines these messages but, as Section 8 explains, does not yet perform the complete production verification path.

6 How an Exchange Earns the Right to Advance

6.1 Identity, sessions, and Capability Leases

User identity, Harness identity, and workload/session identity are separate because they answer different questions: who requested the work, which software installation carried it, and which bounded activity is now in progress. Enrollment gives a Harness a peer credential; it does not grant inference or tool authority. A Working Session binds user, Harness, organization/project, purpose, repository, and effective policy. A Capability Lease then grants a subset of actions for a short interval: permitted models, context paths, tool classes, token budget, and approval requirements. Revocation or expiration prevents new protected actions even if the underlying transport remains healthy.

6.2 Policy Epoch and Relay Verdict

A Policy Epoch freezes the meaning of “allowed” for an exchange. It is an immutable, digest-addressed snapshot rather than a pointer to whatever policy happens to be current when an auditor asks. If policy changes mid-session, active work follows an explicit continue, rebind, pause, or terminate rule; its historical meaning does not silently change. Before protected content reaches a PIA or runtime, the Relay emits a structured verdict such as allow, deny, transform, quarantine, or require approval. The verdict identifies the epoch and rule set that produced it.

6.3 Exchange lifecycle

A typical exchange progresses through OPEN, GOVERNANCE, ROUTE, STREAM, optional TOOL/APPROVAL, and CLOSE. These states are not descriptive labels; they constrain which messages are legal. The Relay validates the peer/session binding, Capability Lease, Policy Epoch, catalog model, model package, endpoint lease, and capacity state before dispatch. Token or data records are multiplexed over lanes with sequence numbers. Side-effecting actions carry an idempotency class so reconnect/resumption cannot silently duplicate a completed operation.

Returning to the motivating incident, the sequence now has crisp answers. The context disclosure is allowed or denied under the lease and epoch before six files leave the Harness. “Code Standard” resolves to a signed package and leased PIA endpoint before inference. The shell string remains a proposal until a separately authorized runtime transition executes it. The final receipt binds these decisions to the evidence root later associated with the commit.

Table 1: Core authority and identity objects. Objects visible to the Harness are intentionally separated from deployment identities.

Object	Authority	Purpose	Important distinction
Peer credential	enrollment authority	Binds key, peer profile, tenant, and validity	Identifies software instance, not merely user
Capability Lease	policy authority	Grants bounded action/model/tool/context scope	Permission; not resource capacity
Policy Epoch	policy authority	Immutable effective policy revision	Exchange binds to a digest, not “latest”
Catalog Model	model catalog	Stable user-facing service identity	Contains no provider endpoint
Model Descriptor	model catalog	Declares semantic capabilities and client minimums	Negotiation, not authorization by itself
Model Package (PMP)	model authority	Signed artifact/template/quantization identity	Stronger than human-readable model name
Endpoint Lease	serving authority	Binds active PIA endpoint to approved package	Short-lived deployment state
Account Capacity Lease	capacity authority	Coordinates distributed workload slots	Capacity; distinct from action permission

6.4 Server-authoritative model resolution

Model names are user experience, not security identities. PAPER therefore separates:

Catalog Model $\rightarrow$ PMP $\rightarrow$ PIA Endpoint.

After authentication, the Harness receives an effective model catalog scoped by entitlement, organization policy, deployment profile, geography, and client capability. A Model Descriptor advertises semantic features—for example multimodal input, structured output, parallel tools, caching, reasoning controls, and resumability—without exposing an endpoint. An inference-open message references the Catalog Model and Catalog Epoch. The Relay rejects stale or unauthorized selections, resolves a signed Patty Model Package (PMP), and selects a PIA endpoint with a valid lease. These are three deliberately different identities: the Catalog Model is the stable product visible to the user, the PMP identifies the approved artifact and serving configuration, and the Endpoint Lease identifies where that package may run now. A caller may express a preference; it cannot turn a string or base URL into trusted infrastructure.

6.5 Tool authority and prompt injection

PAPER’s most important prompt-injection rule fits in one sentence: *model output is a proposal, never authority*. Tool descriptors specify execution placement, risk class, argument schema, approval policy, idempotency, and provenance requirements. Incrementally streamed arguments are not executable until complete and authorized. Repository text, chat, files, and tool output retain trust labels but cannot enlarge lease scope. Prompt injection remains possible, but injected text must cross an authority boundary it does not control. PAPER records both

the proposal and the independent decision that allowed, transformed, or denied execution.

7 Causal Provenance and Receipts

The strongest audit question is not “what events occurred?” but “what caused this artifact to exist under this authority?” The Provenance Spine represents causal edges among human intent, selected context, policy decisions, model invocation, output, tool proposal, approval, execution result, edits, tests, review, and source-control artifacts. Nodes are content-addressed and typed; edges describe causation, derivation, disclosure, transformation, or binding. When the protocol requires a transition, its absence leaves a verifiable gap in that causal account rather than a missing row in an otherwise unrelated log stream. PAPER does not claim that a receipt can reveal an event performed entirely outside the governed path.

For compact exchange integrity, let $r_0 = H(\text{domain} \parallel \text{exchange-open})$ and

$$r_i = H(\text{domain} \parallel r_{i-1} \parallel H(e_i)), \quad (1)$$

where e_i is the canonical representation of evidence event i . A signed Evidence Receipt binds the final root to the exchange, identities, policy epoch, model/package resolution, outcome, and retention/export profile. The receipt is deliberately compact: an auditor given the complete ordered event sequence can recompute the root and verify consistency with the closed exchange. Proving an arbitrary selectively disclosed subset requires an additional commitment or inclusion-proof construction; the current chain primitive alone does not provide it.

The construction provides tamper evidence, not truth by magic. A compromised authorized component can emit false source data, and a coalition controlling every signer

can manufacture a consistent account. Cross-component receipts and external transparency reduce unilateral trust; they do not erase it. This distinction matters because “cryptographically signed” is often mistaken for “factually true.” PAPER claims the former under explicit component assumptions, not the latter.

Selective-export profiles may replace sensitive nodes with commitments or redacted summaries, but their verifiable linkage is a design requirement rather than a property established by the current chain benchmark. Source-code attribution after refactoring or merging is probabilistic and should carry confidence and transformation history rather than a binary “AI-generated” label.

8 From Design to a Running Exchange

We built a Go prototype to test whether the design can become an executable protocol rather than remain a diagram. The evaluated snapshot is repository commit 0234034. It implements a 32-byte record prelude, bounded headers and payloads, canonical CBOR helpers, COSE Sign1 support, Ed25519 object signatures, content-addressed digests, evidence-chain primitives, peer/session state machines, TLS/TCP transport, a QUIC transport foundation, model/catalog schemas, policy and lease services, Relay/PIA components, vLLM/SGLang adapters, and conformance tests.

The current vertical slice routes an inference request from Relay to PIA over a PAPER TLS/TCP connection using `AI_OPEN` and `AI_COMPLETE` records. The PIA translates the request to a model-serving adapter and normalizes the response. This demonstrates the proposed trust placement: the Harness-facing route terminates at an enrolled protocol peer rather than at a user-supplied model endpoint.

This is not yet the exchange described in the strongest version of the design. The embedded AI semantic payload is JSON rather than the final canonical encoding, and a legacy HTTP development fallback remains when the PAPER PIA address is absent. More importantly, the listener accepts development proof material without complete COSE-signature, revocation, certificate, and transcript verification. One catalog path validates presence rather than the effective catalog, and capacity/scheduler gates contain permissive stubs. Table 2 makes this boundary explicit. We treat incomplete enforcement as an evaluation result about prototype maturity, not as a footnote to hide.

9 Evaluation: What Must Be True for PAPER to Matter?

A governance-native protocol is useful only if it makes authority materially more enforceable without making

interactive AI unusable. The evaluation therefore asks: (Q1) what connection and pre-inference latency does PAPER add; (Q2) how does Relay cost scale with streams; (Q3) what evidence and storage cost buys a verifiable causal path; (Q4) which adversarial cases are rejected by protocol state rather than conventions; and (Q5) how accurately provenance survives real software evolution?

9.1 Baselines

We define five goal-aware baselines: B0, a minimal secure binary stream; B1, bearer-authenticated HTTPS/JSON streaming; B2, HTTPS/JSON plus comparable gateway policy and logging; B3, PAPER with identity/session and minimal governance; and B4, PAPER with lease, policy, content checks, verdicts, and provenance. The crucial comparisons are B2 versus B4 (comparable governance, different lifecycle) and B3 versus B4 (the marginal cost of governance). MCP and A2A are semantic neighbors, not performance strawmen.

End-to-end experiments must report connection p50/p95/p99, time to first Relay verdict, TTFT, inter-token latency, sustained throughput, CPU time, allocation, memory per stream, and evidence bytes. The environment disclosure must include CPU, memory, NIC, RTT, topology, OS, Go and QUIC versions, model/quantization, GPU, policy modules, and storage backend.

9.2 Security and provenance experiments

Negative tests include an unknown peer, expired/replayed lease, unknown Policy Epoch, stale catalog, unapproved model package, invalid endpoint lease, profile-confused message, malformed state sequence, duplicate side effect after resume, prompt-injected capability escalation, and modified receipt. Provenance fidelity should be measured on generated functions followed by human edits, file renames, function moves, rebases, merges, and multi-agent changes. Precision/recall and confidence calibration are more appropriate than anecdotal examples.

10 Preliminary Results: Are the Protocol Primitives Obviously Too Expensive?

10.1 Experimental setup

Our first question is intentionally modest: before building the complete B0–B4 experiment, are PAPER’s basic framing and evidence operations already expensive enough to invalidate the design? Measurements ran locally on an Apple M4 Pro with 14 logical CPUs and 48 GiB RAM, macOS 27.0, arm64, and Go 1.26.5. Each Go benchmark was repeated five times; Table 3 reports the median. No network, database, model, GPU, policy classifier, or token

Table 2: Evidence boundary of the evaluated prototype. “Partial” means relevant code exists but the complete stated property is not exercised end to end.

Mechanism or property	Status	What we exercised	What the evidence establishes
Record framing and bounded parsing	Implemented	round-trip tests and microbenchmarks	Primitive cost and parser behavior
Canonical CBOR and signature primitives	Implemented	unit tests and microbenchmarks	Primitive correctness and cost
Tamper-evident evidence-chain update	Implemented primitive	deterministic mutation tests and microbenchmark	Mutation changes the root under stated hash assumptions
TLS/TCP Relay-to-PIA PAPER exchange	Partial	implementation and package tests	A development vertical slice runs
Authenticated Harness-to-Relay exchange	Partial	message/state tests; proof verification incomplete	Message lifecycle, not production authentication
Catalog Model authorization	Partial	schemas/service tests; permissive pipeline path	Authority model is encoded but not closed end to end
Account-wide distributed capacity enforcement	Design/scaffold	schema and service scaffolding	No enforcement result
Research invariant enforcement	Not established	eleven named tests; several weak/placeholders	Candidate suite, not twelve proven properties
Production latency, TTFT, scale, provenance fidelity	Unmeasured	methodology only	No system-level result

Table 3: Preliminary in-memory primitive medians over five runs. Record tests include encode and decode.

Operation	Time/op	B/op	allocs
Record, 1 KiB	290.2 ns	2,384	7
Record, 64 KiB	8.46 μ s	139,472	7
Record, 1 MiB	97.0 μ s	2,105,556	7
CBOR Hello round trip	599.4 ns	592	9
Evidence-chain update	73.05 ns	32	1
1 KiB object digest	403.1 ns	32	1
Ed25519 sign+verify	42.7 μ s	64	1

generation was involved.

The immediate answer is no: none of the measured primitives is an obvious showstopper. Record encode/decode scales approximately linearly across the measured sizes, reaching 97.0 μ s for a 1 MiB payload. The 73.05 ns evidence-chain update is small enough to apply per evidence event, and a 42.7 μ s sign-and-verify operation is plausible at exchange or receipt boundaries rather than per token. The benchmark allocates an encoded buffer and decoded record on every iteration; bytes allocated are therefore roughly twice the large payload size and identify a concrete optimization target.

This is encouraging but easy to overread. Complete provenance also requires canonical event construction, persistence, indexing, retention, and potentially multiple signatures. The current measurements say that the low-level mechanism is not obviously prohibitive. They do not say that governance is free.

The full repository suite passed at the evaluated commit. More revealingly, our coverage audit found that the

conformance package’s names overstate its present evidence. It exposes tests named for invariants 1–5 and 7–12, with no named test for invariant 6; several passing tests exercise only a proxy for their stated property. For example, the Policy Epoch test checks connection readiness rather than unknown-epoch rejection, and the reconnect test contains no assertion. This finding changed the paper: we report passing code tests, not “twelve invariants enforced.” The detailed audit appears in Appendix A.

10.2 Interpretation

The primitive results earn the design permission to proceed, not permission to declare victory. The dominant cost may live in TLS/QUIC establishment, policy modules, database/cache access, content classifiers, network placement, model scheduling, or evidence storage. Only the B0–B4 experiment can establish system overhead. Likewise, only negative tests through the actual Relay path can establish that the protocol state rejects the attacks claimed by the design.

11 What PAPER Changes—and What It Does Not

Table 4 locates novelty in composition and lifecycle semantics rather than lower-layer mechanisms. A sufficiently sophisticated conventional gateway could implement many PAPER concepts. That observation does not collapse the contribution; it sharpens the experiment. The question is whether leaving these semantics as deployment-specific middleware is adequate, or whether shared state transitions and evidence objects produce stronger interoperabil-

Table 4: Goal-aware qualitative comparison. A blank objective is not a deficiency when a system intentionally addresses another boundary.

System family	Primary boundary	Live purpose-bound authority	Inline model/package identity	Interactive causal code provenance
Model API	application-model service	typically application-defined	usually caller-visible model identifier	external
AI gateway	application-provider mediation	gateway/policy dependent	provider-route dependent	logs/plugin-ins
MCP	AI application-tool/context provider	authorization is deployment-specific	not its objective	not its objective
A2A	agent-agent task/artifact exchange	protocol/task dependent	not its objective	not its objective
in-toto/SLSA	software supply-chain steps/artifacts	step/build policy	artifact identity	post-step/build provenance
PAPER	Harness-Relay-PIA/runtime	Capability Lease + Policy Epoch	Catalog Model + PMP + Endpoint Lease	native exchange graph/receipt

ity, fewer ambiguous authority gaps, and better failure behavior. PAPER should be judged on that difference, not on whether its bytes are uniquely expressible over HTTP.

12 Security Consequences of Externalizing Authority

PAPER does not make the model trustworthy. It changes what an untrusted or manipulated model is able to authorize. An unregistered generic client lacks a valid peer credential and session grant. A stolen Harness key remains bounded by lease lifetime, repository/purpose scope, revocation, and optional device evidence. A fake model name cannot select an endpoint when the Relay resolves only an authorized Catalog Model through a signed PMP and active Endpoint Lease. Most importantly, a prompt-injected tool call cannot grant itself authority because execution requires an independent lease/policy transition outside the model’s output channel.

Replay protection requires transcript-bound authentication and idempotency evidence. Transport fallback must preserve the same authorization objects and state machine. Evidence tampering changes the chain root, while an attacker able to compromise all receipt signers can still forge a consistent account. A malicious inspectable Relay can read plaintext and may omit or distort events; cross-component receipts, limited retention, independent export, and optional payload protection reduce but do not eliminate this trust.

The prototype does not yet establish these end-to-end properties. In particular, placeholder proof material and permissive certificate verification mean that the development transport must not be described as production peer authentication.

13 Can This Replace a Gateway Without a Flag Day?

One protocol kernel can support public cloud, enterprise, and sovereign profiles by varying enabled modules, policy defaults, retention, mobility, and infrastructure placement rather than forking wire semantics. Sovereign deployment may use local PKI, catalogs, PIA endpoints, and offline-signed update bundles. This is a design target, not an interoperability result.

Because PCCP already has administrative and legacy request paths, adoption is necessarily brownfield. A safe sequence inventories callers, introduces catalog/control schemas additively, runs the PAPER Relay beside the legacy gateway during observation, dual-records comparable requests, canaries Harness cohorts, blocks generic routing for migrated clients, and removes the old path only after telemetry and rollback gates are satisfied. This migration produces a valuable experiment: for the same user task, compare normalized usage, chosen model package, tool outcome, and reconstructable evidence between the legacy and governed paths. The target invariant remains strict: after migration, the official Harness uses PAPER for service communication and exposes no generic model-provider fallback; administrative and PIA-local adapter APIs remain outside that Harness trust path.

14 Discussion: From Message Protocols to Consequence Protocols

The broader implication of PAPER is that agent protocols may need to evolve from moving messages to governing consequences. When a system only returns text, request authentication and application logs may be sufficient. When it discloses private context, invokes tools, mutates

repositories, and creates durable artifacts, the protocol boundary becomes a security boundary. Authority is no longer metadata about the conversation; it determines which state transitions the conversation is allowed to cause.

This does not imply that every AI application needs PAPER, or that one protocol should absorb every adjacent standard. It suggests a criterion: the more durable and privileged the agent’s effects, the less acceptable it is to reconstruct authority solely after execution. PAPER is one concrete design point for that regime.

Scope pressure. Inference, tools, context, files, chat, voice, and directives can share identity and session infrastructure, but a broad substrate increases implementation and review cost. The core paper is strongest when these are capability-separated extensions rather than equally mature contributions.

State and operations. Leases, epochs, resumption, revocation, catalogs, and evidence add operational burden. Cache staleness and control-plane partitions require explicit fail-closed, bounded-stale, or degrade behavior. Binary framing also requires first-class diagnostics and capture tooling.

Privacy. Fine-grained provenance can become employee surveillance. Deployments need purpose limitation, minimization, role-separated access, retention bounds, selective export, and notice. Content-addressing does not anonymize sensitive content; unsalted hashes can enable guessing attacks.

Implementation maturity. Only primitive overhead is measured. Production authentication, complete catalog/capacity enforcement, QUIC/TCP equivalence, independent interoperability, fuzzing, security review, scale, TTFT, and provenance-fidelity datasets remain open. The legacy development fallback and JSON semantic payload must be removed or formally profiled before claiming a PAPER-only canonical path. The current artifact establishes feasibility of primitives and a development vertical slice, not production security.

No formal proof. The state machine and invariants are candidates for formal modeling, but no formal security proof is claimed. Provenance establishes recorded causality under component assumptions, not semantic correctness or authorship truth.

15 Ethics: Evidence Can Become Surveillance

Evidence about prompts, files, tool use, edits, and human decisions can improve incident response and accountability while also enabling disproportionate monitoring. The

protocol therefore supports retention and export profiles, but technical configurability is insufficient. Deployments should establish lawful purpose, employee notice, access review, appeal, data-subject handling, and a separation between security investigations and performance management. Public deployments should default to operationally minimal traces; regulated deployments should justify deeper retention per policy domain.

Generated conceptual artwork is used only for Figure 1; it communicates architecture and contains no measurement or factual comparison. Empirical tables are derived from the checked-in benchmark dataset; raw per-run output remains a requirement for a complete empirical release.

16 Reproducibility

The arXiv source package contains the exact LaTeX source, bibliography, conceptual figure, benchmark dataset, and build instructions. The evaluated repository snapshot contains the Go benchmark harness and implementation. From that repository root, the preliminary measurements can be reproduced with:

```
go test ./internal/paper -run '$' -bench
'Benchmark(...)' -benchmem -count=5
```

where the artifact README provides the complete regular expression. The PDF builds offline with `latexmk` and BibTeX. A complete empirical release should additionally publish raw per-run output, network/load generators, topology automation, negative-security fixtures, provenance datasets, and independent implementation results.

17 Conclusion

When an AI agent creates a commit, “which model produced these tokens?” is not the hardest question. The harder question is whether the entire path from human intent to durable effect remained inside an authority that no prompt, model output, stale alias, or middleware gap could silently enlarge.

PAPER’s answer is the Governed Exchange: bind identity, purpose, bounded capability, immutable policy, model/package resolution, inline enforcement, and causal evidence into the live protocol lifecycle. The model can propose; it cannot mint authority. The system can later show not merely that events were logged, but why the protected transitions were permitted and how their outputs reached an artifact.

Our Go prototype shows that this idea can be rendered as concrete framing, canonical objects, signatures, evidence chaining, state machines, and a Relay-to-PIA path. Preliminary measurements find no obvious primitive-cost barrier. They do not establish end-to-end overhead or production security, and the implementation audit exposes important missing enforcement tests.

The next threshold is therefore empirical: complete authentication, execute the B0–B4 comparisons, attack the real state machine, demonstrate independent interoperability, and measure whether provenance survives actual software evolution. If those results hold, AI infrastructure gains something it largely lacks today: a protocol-level answer to *who authorized this commit?*

References

- [1] A2A Project. Agent2agent protocol specification, 2026. <https://a2a-protocol.org/latest/specification/>.
- [2] R. Barnes, K. Bhargavan, and C. A. Wood. Hybrid public key encryption. Technical Report RFC 9180, IETF, Feb. 2022. <https://www.rfc-editor.org/info/rfc9180>.
- [3] C. Bormann and P. Hoffman. Concise binary object representation (CBOR). Technical Report RFC 8949, IETF, Dec. 2020. <https://www.rfc-editor.org/info/rfc8949>.
- [4] E. Debenedetti, J. Zhang, M. Balunović, L. Beurer-Kellner, M. Fischer, and F. Tramèr. AgentDojo: A dynamic environment to evaluate prompt injection attacks and defenses for llm agents. *arXiv preprint arXiv:2406.13352*, 2024. <https://arxiv.org/abs/2406.13352>.
- [5] L. Fan, Z. Li, Y. Tian, Y. Wang, R. Li, and X. Wang. The granularity mismatch in agent security: Argument-level provenance solves enforcement and isolates the llm reasoning bottleneck. *arXiv preprint arXiv:2605.11039*, 2026. <https://arxiv.org/abs/2605.11039>.
- [6] in-toto Project. in-toto specification v1.0, 2023. <https://in-toto.io/docs/specs/>.
- [7] J. Iyengar and M. Thomson. QUIC: A UDP-based multiplexed and secure transport. Technical Report RFC 9000, IETF, May 2021. <https://www.rfc-editor.org/info/rfc9000>.
- [8] Model Context Protocol Project. Model context protocol specification, 2025-06-18 revision, 2025. <https://modelcontextprotocol.io/specification/2025-06-18>.
- [9] E. Rescorla. The transport layer security (tls) protocol version 1.3. Technical Report RFC 9846, IETF, July 2026. <https://www.rfc-editor.org/info/rfc9846>.
- [10] J. Schaad. CBOR object signing and encryption (COSE): Structures and process. Technical Report RFC 9052, IETF, Aug. 2022. <https://www.rfc-editor.org/info/rfc9052>.
- [11] SLSA Project. SLSA specification v1.2, 2026. <https://slsa.dev/spec/v1.2/>.
- [12] SPIFFE Project. Secure production identity framework for everyone standard, 2026. <https://spiffe.io/docs/latest/spiffe-specs/spiffe/>.
- [13] O. Steele, H. Birkholz, A. Delignat-Lavaud, and C. Fournet. CBOR object signing and encryption (COSE) receipts. Technical Report RFC 9942, IETF, June 2026. <https://www.rfc-editor.org/info/rfc9942>.
- [14] S. Torres-Arias, H. Afzali, T. K. Kuppusamy, R. Curtmola, and J. Cappel. in-toto: Providing farm-to-table guarantees for bits and bytes. In *28th USENIX Security Symposium*, pages 1393–1410, 2019.
- [15] C. L. Wang, T. Singhal, A. Kelkar, and J. Tuo. MI9: An integrated runtime governance framework for agentic ai. *arXiv preprint arXiv:2508.03858*, 2025. <https://arxiv.org/abs/2508.03858>.

A Research Invariant Coverage

Table 5 audits the conformance-test coverage at the evaluated commit. “Weak” denotes an assertion that does not exercise the full invariant stated by its test name; “partial” denotes a meaningful primitive or state check without a complete end-to-end path.

Table 5: Coverage audit of the candidate research invariants.

ID	Candidate invariant	Coverage	Audit note
I1	No protected action before peer authentication	Partial	connection-state gating asserted; listener proof verification incomplete
I2	No protected action outside a valid Capability Lease	Weak	test checks credential time validity, not action authorization
I3	No action under an unknown Policy Epoch	Weak	test checks connection readiness, not epoch lookup/rejection
I4	No invocation against an unapproved package/endpoint lease	Partial	signature mutation tested; full route binding not exercised
I5	Tool proposal grants no authority by itself	Weak	test checks only a valid peer credential
I6	Context disclosure requires explicit authority	Missing	no named conformance test
I7	Transport fallback preserves authorization semantics	Weak	ALPN constant checked; fallback exchange not exercised
I8	Reconnect does not duplicate completed side effects	Placeholder	named test has no assertion
I9	Protected exchange terminates with verifiable evidence	Partial	deterministic chain checked; termination/receipt path not exercised
I10	Provenance mutation changes digest	Implemented primitive	distinct content produces distinct domain-separated digest
I11	Peer profiles cannot emit privileged messages	Placeholder	message list is constructed but not passed through enforcement
I12	Administrative communication and enforcement are distinct	Structural	distinct message type codes asserted

A.1 Required Completion Experiments

The following gates separate the preliminary artifact from a complete empirical revision:

1. **Transport and authentication:** exercise full certificate and COSE proof verification, revocation, transcript binding, resumption, and QUIC-to-TCP fallback with p50/p95/p99 connection measurements.
2. **End-to-end inference:** compare B0–B4 on identical payloads and model output, reporting Relay verdict latency, TTFT, streaming throughput, CPU, allocation, and memory.
3. **Governance negatives:** reject expired/replayed leases, unknown epochs, stale catalogs, unapproved packages, invalid endpoints, profile-confused messages, and duplicate side effects through the actual Relay path.
4. **Scale and failure:** measure concurrent sessions/streams, Relay restart, control-plane loss, bounded-stale caches, capacity-authority loss, and evidence-backend degradation.
5. **Provenance fidelity:** publish a labeled dataset covering human edits, file/function moves, rebases, merges, and multi-agent changes with precision, recall, and confidence calibration.
6. **Independent evidence:** demonstrate an implementation not sharing the complete Go stack, publish golden vectors/fuzz results, and obtain an external security review before a production-security claim.